05 · Login: Akun Lokal & LDAP / Active Directory (opsional)

Dua mode login, dipilih otomatis dari `.env`:

`LDAP_SERVERS`	Mode	Siapa membuat akun
kosong (bawaan instalasi baru)	**akun lokal** — password disimpan terenkripsi di metadata	Admin: **Settings → List Users → +**
terisi	**LDAP / Active Directory** — username & password jaringan kantor	otomatis saat login pertama; akun lokal darurat tetap bisa (`AUTH_LOCAL_USERS`)

LDAP tidak wajib. Akun ber-email (Superadmin & pengguna yang dibuat installer) **selalu** login sebagai akun lokal, juga saat LDAP aktif atau server LDAP mati. Username jaringan (tanpa `@`) diperiksa ke LDAP. Bawaan nilai LDAP kosong: LDAP hanya dipakai bila `LDAP_SERVERS` diisi (installer halaman *Login kantor*, atau `.env`).

> Penguncian: salah password berulang mengunci akun sementara, termasuk akun LDAP, sebelum LDAP ditanya lagi (bawaan 5 kali / 15 menit, 14 §4.5).
> Keamanan: pakai `ldaps://` (terenkripsi). Dengan `ldap://` password pengguna berjalan tanpa enkripsi di jaringan.

Halaman login sama untuk kedua mode (beranimasi, mengikuti Identitas & Tema). Sisa dokumen ini membahas mode LDAP. Contoh nilai memakai domain rekaan `kantor.local`; minta nilai aslinya ke tim TI.

Cara kerja

```
Form login Superset
       | username, password
       ▼
sps_security.py ── username ada di AUTH_LOCAL_USERS? ──► ya ──► cek password di database Superset
       | tidak
       ▼
sps_ldap.py ── bind DOMAIN\username ──► server LDAP 1  (gagal terhubung? ──► server LDAP 2)
       | berhasil
       ▼
cari data pengguna di LDAP_SEARCH_BASE
       | nama (displayName), nomor pegawai (employeeNumber), email (mail)
       ▼
user Superset dibuat otomatis (login pertama) → masuk
```

File	Tugas
`config/sps_ldap.py`	Bicara dengan Active Directory (pakai `ldap3`). Bisa dites sendiri.
`config/sps_security.py`	Menyambungkan hasil LDAP ke user & role Superset.

File	Tugas
`config/superset_config.py`	`AUTH_TYPE = AUTH_LDAP` bila `LDAP_SERVERS` terisi, selain itu `AUTH_DB` (akun lokal).

Mengapa `ldap3`, bukan LDAP bawaan Superset? Bawaan Superset butuh `python-ldap` yang harus dikompilasi dan diunduh dari internet, dan itu diblokir jaringan kantor. `ldap3` murni Python dan dipasang offline dari `docker\wheels\`.

Pengaturan (`.env`)

Variabel	Contoh	Arti
`LDAP_SERVERS`	`ldaps://dc1.kantor.local,ldaps://dc2.kantor.local`	Server AD, dicoba berurutan. **Kosong = LDAP mati**
`LDAP_DOMAIN`	`KANTOR`	Prefix login: `DOMAIN\username`
`LDAP_SEARCH_BASE`	`OU=Karyawan,DC=kantor,DC=local`	Tempat data pengguna dicari
`LDAP_DEFAULT_ROLE`	`Gamma`	Role pengguna saat login pertama
`SPS_ROLE_PENGGUNA`	`Pengguna`	Role dasar tambahan untuk semua pengguna LDAP: menu Studio, Asisten AI
`LDAP_ADMIN_USERS`	(kosong)	Username yang otomatis jadi Admin. Boleh lebih dari satu, pisahkan koma: `budi.santoso,siti.rahayu`
`SPS_KUNCI_BERKAS`	kosong	Kunci berkas .ald/.aldx "kunci server"; samakan antar-server untuk berbagi berkas (25)
`SPS_SUPERADMIN_USERS`	email Superadmin + username jaringan opsional dari installer	Username yang otomatis jadi **Admin + Superadmin** (pengaturan vital). Contoh: `budi.santoso` (24)
`AUTH_LOCAL_USERS`	`admin`	Akun lokal darurat tanpa `@` (tidak lewat LDAP). Username ber-`@` otomatis akun lokal

Setelah mengubah `.env`: `scripts\stop.ps1` lalu `scripts\start.ps1`.

Role Superset

Role	Bisa apa
`Gamma`	Melihat dashboard yang dibagikan kepadanya
`Alpha`	+ membuat chart & dashboard, akses semua data
`Admin`	Semua, termasuk kelola user & koneksi database

Role per orang bisa diubah oleh Admin di **Settings → List Users**.

Langkah pemakaian

1. Isi `LDAP_ADMIN_USERS` di `.env` dengan username Anda (agar Anda jadi Admin).
2. Tes koneksi LDAP dulu, tanpa membuka Superset: `powershell powershell -ExecutionPolicy Bypass -File scripts\test-ldap.ps1` Harus muncul `BERHASIL: LdapUser(username=..., display_name=..., nomor_pegawai=...)`.
3. Nyalakan Superset, login dengan username & password jaringan kantor.

Aturan keamanan yang sengaja dipasang

- **Password kosong selalu ditolak.** AD menganggap password kosong sebagai *anonymous bind* yang "berhasil".
- **Password salah tidak dicoba ulang ke server cadangan.** Server cadangan hanya dipakai bila server utama *tidak bisa dihubungi*, supaya akun AD tidak cepat terkunci.
- **Tanpa akun layanan.** Tiap orang login memakai kredensial sendiri (tidak ada password akun layanan yang disimpan di server).
- **Akun `admin` lokal** tetap ada untuk darurat (VPN/LDAP mati). Pakai password yang kuat.

Masuk dengan SSO (OpenID Connect)

Tombol **Masuk dengan Microsoft / Google / …** di halaman login, memakai akun perusahaan yang sudah ada (termasuk MFA dan kebijakan login perusahaan). SSO adalah jalan masuk **tambahan**: formulir password (akun lokal & LDAP) tetap ada, sehingga Superadmin tetap bisa masuk bila penyedia SSO atau internet bermasalah.

1. Daftarkan aplikasi di penyedia

Penyedia	Tempat mendaftar	Alamat discovery (`SSO_DISCOVERY_URL`)
Microsoft Entra ID (Azure AD)	Entra admin center › App registrations › New registration (Web)	`https://login.microsoftonline.com/<ID-tenant>/v2.0/.well-known/openid-configuration`
Google Workspace	Google Cloud Console › APIs & Services › Credentials › OAuth client ID (Web)	`https://accounts.google.com/.well-known/openid-configuration`
Keycloak	Realm › Clients › Create (OpenID Connect, client authentication ON)	`https://<server>/realms/<realm>/.well-known/openid-configuration`
Okta	Applications › Create App Integration (OIDC, Web)	`https://<domain-okta>/.well-known/openid-configuration`

Alamat kembali (*redirect URI*) yang didaftarkan: `https://<alamat-aldx>/sso/kembali`. Catat **client ID** dan **client secret**.

2. Isi `.env` (lalu `docker compose up -d`):

```
SSO_DISCOVERY_URL=https://login.microsoftonline.com/<ID-
tenant>/v2.0/.well-known/openid-configuration
SSO_CLIENT_ID=...
SSO_CLIENT_SECRET=...          # rahasia, hanya di .env
SSO_NAMA=Microsoft             # label tombol
SSO_DOMAIN=kantor.co.id        # hanya email domain ini yang boleh masuk
SSO_BUAT_AKUN=0                # 0 = hanya email yang sudah didaftarkan
Admin; 1 = akun dibuat otomatis (role SSO_ROLE_BAWAAN)
SSO_ROLE_BAWAAN=Gamma
```

Hal	Perilaku
Akun dicocokkan	menurut **email** (klaim `email`, atau `preferred_username` / `upn` dari Microsoft)
Email belum terverifikasi / domain lain	ditolak dengan pesan jelas; tercatat di jejak audit
Keamanan	authorization code + PKCE, `state` & `nonce`, tanda tangan id_token diperiksa dengan kunci publik penyedia (JWKS), penerbit, audiens & kedaluwarsa
Superadmin / Admin	`SPS_SUPERADMIN_USERS` & `LDAP_ADMIN_USERS` tetap berlaku (isi dengan email)
Penyedia mati	pengguna melihat pesan; login password tetap bisa dipakai

Kode: `config/sps_sso.py` (rute `/sso/masuk`, `/sso/kembali`), tombol di `config/sps_identitas/login.html`.

Mode akun lokal (tanpa LDAP)

1. Kosongkan `LDAP_SERVERS` di `.env`, lalu `scripts\start.ps1`.
2. Login sebagai `admin` → **Settings → List Users → +** → isi username, nama, email, **role** (`Gamma` + `Pengguna` untuk menu Studio Visual & Asisten AI, + role cabang/divisi bila memakai RLS), dan password awal.
3. Berikan password awal ke pengguna secara pribadi; pengguna bisa menggantinya di menu profil (**Settings → Info → Reset my password**).